

银行业防御 AI 代理网关

项目汇报材料 / 当前 Demo 成果更新版

安全架构与 AI 工程联合评审

2026-07-15

版本：Demo 阶段汇报 v2.0

汇报口径：以当前代码、数据库和 2026-07-15 Demo 回放结果为准

产品定位：安全产品与分析师之间的受控智能中枢

核心结论

项目路线没有偏离最初设计：仍以“证据优先、只读分析、产品专属 Agent、受控记忆、人工审批、全链路审计、离线可迁移”为主线。当前 Demo 已从早期的单告警分析样机，推进到可接入、可排队、可调用真实 Gateway、可形成 Case、可治理记忆、可审批但不执行的完整验证链路。

需要同时明确：当前成果是 **工程链路和治理边界的 Demo 验收**，不是生产准确率、容量、可用性或外部系统集成已经达标。Demo 样本带有受信任的期望结论校正，用于验证展示一致性，不能替代盲测样本集上的模型质量评估。

目录

章节	内容
一	管理层摘要
二	产品路线复核
三	当前 Demo 成果
四	建议的现场演示流程
五	业务痛点与能力映射
六	安全治理成果
七	当前差距与风险
八	下一阶段路线
九	管理决策建议
附录	复核证据与汇报口径

一、管理层摘要

1.1 本轮复核结论

维度	结论	当前事实
产品路线	符合最初设计	不替代 HIPS/RASP/NDR/WAF/SIEM，不直接执行生产处置，聚焦告警解释、证据关联、建议与治理
Demo 完整度	已形成端到端闭环	接入 → 映射 → 持久队列 → Agent/LLM → Validator → Case/审批 → 记忆 → Dashboard/审计
模型运行	已使用真实 Gateway	复核批次 15 条均由 gateway / claude-sonnet-4-6 完成，fallback_used=0
运营可视化	已覆盖核心工作面	监控大屏、Case 处置台、记忆治理、日志接入、模型配置；队列可区分未完成、等待和分析中
生产边界	仍需企业集成	PostgreSQL、CMDB/IAM、企业向量服务、mTLS 接入层、SOAR/工单执行回写尚未落地
工程质量	主链路可验证，仍有发布阻断项	当前发现 183 个自动化测试；评审运行 181 通过、2 个现有断言需在对外发布前修复

1.2 当前 Demo 的量化快照

指标	结果	说明
Demo 告警数	15	同一批次提交，均进入 durable inbox
产品覆盖	5	HIPS / RASP / NDR / WAF / SIEM，各 3 条
场景覆盖	3	attack / suspicious / false_positive，各 5 条
严重级别覆盖	4	critical / high / medium / low
实际模型后端	Gateway	claude-sonnet-4-6，15 条均无本地降级
Worker 并发	4	批量提交后可观察到 4 条分析中、11 条等待
完成耗时区间	24.0–211.8 秒	当前 Gateway 条件下的单次 Demo 观测，不作为 SLA 承诺
最终状态	15 completed	无 dead-letter

1.3 这次最重要的产品进展

- 从“模型回答”升级为“受治理的告警处理系统”：模型前后均有确定性控制，输出进入 Validator、审批、审计和记忆生命周期。
- 从“同步演示”升级为“真实异步入口”：HTTP 在持久化告警后返回 202，worker 后台分析，失败可重试并进入 DLQ，进程重启可恢复。

- 3. 从“固定样本字段”升级为“真实日志适配”：五产品内置 Mapping Profile，支持自动指纹识别、字段映射推断和 dry-run，无法识别来源时拒绝而不是静默误路由。
- 4. 从“单次结论”升级为“受控经验复用”：产品长期记忆经过匹配评分、人工确认、范围和过期门禁后才能影响后续告警。
- 5. 从“本地模型验证”升级为“真实 Gateway 调用”：当前运行时配置已切换到企业式 Gateway 适配路径，并记录每次结果的实际 provider、model 和 fallback 状态。

二、产品路线复核

2.1 最初想法没有变化

项目仍然定位为银行 SOC 的 **受控智能分析层**，而不是替换现有安全产品或建设一个绕过治理流程的自动化处置机器人。

坚持项	当前落地
证据优先	RawAlert、NormalizedEvent、evidence refs、Agent Run、Case Link 均持久化；结论需引用证据和缺口
最小权限	默认 read_only；高影响动作只能变成 approve_required 建议
上下文隔离	五类产品使用独立 Agent、提示词、Skill 与产品记忆命名空间
人工在环	Validator 通过后才可形成审批；批准仍保持 not_executed
可回放评测	Harness 与 HTTP 共用同一条 Orchestrator 路径，支持静态、随机、真实映射样本回放
合规内建	prompt 前脱敏、端点/主机 allowlist、角色 Token、审计、离线部署与生产失败关闭配置

2.2 明确非目标

- 不让 AI 直接封禁 IP、隔离主机、停用账号或修改安全策略。
- 不把模型输出当作事实真相；结论必须经过证据、结构化契约和 Validator 复核。
- 不把 Demo 样本的期望结论当作模型准确率证明。
- 不宣称已经完成 Kafka、CMDB、IAM、PostgreSQL、企业向量库、SOAR/工单执行集成。
- 不在应用内自行实现生产 TLS；生产应由 API Gateway、反向代理或 Ingress 提供 TLS/mTLS 与网络边界。

2.3 当前实现与目标态的关系

当前 Demo	目标态演进	保持不变的契约
SQLite v9 单实例事实库	PostgreSQL / 企业关系库	RawAlert、NormalizedEvent、Case、Run、Audit 的结构化事实关系
HTTP + 内嵌/Vector Syslog	API Gateway、Kafka、厂商 API	统一 RawAlert 与 Mapping Profile 数据合同

当前 Demo	目标态演进	保持不变的契约
稳定哈希向量与确定性匹配	企业 Embedding + pgvector/向量库	匹配分项、阈值决策、审计记录和恶意证据否决权
本地/外部 Gateway 可切换	企业 LLM Gateway / 私有模型	provider 抽象、结构化输出、失败降级和运行元数据
内置审批状态机	企业 IAM、工单、SOAR	人工主体、双签、理由、回滚条件和不可直接执行边界

三、当前 Demo 成果

3.1 已实现能力矩阵

能力域	状态	当前成果
五产品接入	已实现	HIPS/RASP/NDR/WAF/SIEM 标准 JSON、Mapping Profile、自动 Profile、Syslog 端口路由
持久异步队列	已实现	SQLite durable inbox、202、worker pool、有限重试、DLQ、重启恢复、容量回压
产品专属 Agent	已实现	五个 Agent、独立 prompt version、analysis focus、Skill 边界
LLM 可插拔	已实现	local / Ollama / Gateway ; Anthropic Messages 与通用 JSON ; 熔断、限时、响应大小限制
模型失败降级	已实现	Gateway/Ollama 异常时使用 LocalHeuristicLLM , 并在结果标记 fallback
Validator	已实现	输出契约、证据、提示注入、敏感信息、动作权限、Skill 边界的确定性检查
处置审批	已实现但不执行	单签 Demo / 双签生产配置 ; distinct actor 投票 ; 状态单向迁移 ; 执行状态固定为 not_executed
多层记忆	已实现	Case 短期、产品长期、资产画像、组织知识、只读证据 ; 晋升、拒绝、隔离、恢复、过期、冲突检测
记忆匹配	已实现	结构化 + 语义 + retrieval key 混合评分 ; review/apply 阈值 ; 恶意证据否决 ; 匹配审计
Dashboard	已实现	监控、Case、记忆治理、日志接入、模型配置 ; 中英文、深浅色、角色感知
离线迁移	已实现物料	Docker/systemd/k3s、不可变镜像与生产配置校验、备份回滚、Vector Collector 模板
外部企业系统	未集成	CMDB/IAM/SOAR/工单/PostgreSQL/企业向量服务仍属于下一阶段

3.2 Demo 告警覆盖

15 条标准 Demo 按“每产品 3 条、每结论 5 条”设计，避免只展示攻击样本：

结论	验证目的	展示重点
malicious / 真实攻击	证据充分且风险明确	危险行为、产品动作、影响面、处置建议、审批候选
suspicious / 需人工复核	证据不完整或缺闭环	明确缺失证据，避免模型强行下结论
benign / 误报	业务窗口、巡检、备份或批准脚本	误报解释、确认入口、记忆写回与后续降噪

3.3 Gateway 使用情况

本轮 Demo 不是本地规则直接生成结果：数据库中 15 条 Agent Run 均记录：

- provider = gateway
- effective_provider = gateway
- model = claude-sonnet-4-6
- fallback_used = false

如果 Gateway 超时、网络失败或结构异常，Orchestrator 才会进入本地启发式降级，并在摘要与 model_runtime 中明确标记，不会静默假装仍是远程模型结果。

3.4 Demo 真值校正的正确解释

Demo 脚本会发送 X-Defensive-AI-Demo-Sample: 1。该头只在回环、无 Token 的受信 Demo 条件下生效，服务端随后允许读取样本中的 expected_verdict。对模型型后端，最终分类和证据维度可能由样本真值校正，模型主要补充解释文本。

因此当前 Demo 可以证明：

- Gateway 被真实调用；
- 结构化响应可解析；
- 完整治理链路可运行；
- Dashboard 展示与样本预期一致；
- Gateway 失败时可降级。

当前 Demo 不能单独证明：

- 模型在未知真实告警上的准确率；
- 置信度校准已经完成；
- 高峰容量和生产 SLA 已达标；
- 不带样本真值的盲测质量已达标。

四、建议的现场演示流程

4.1 演示前准备

- 6. 确认 Dashboard“模型服务”显示 gateway / claude-sonnet-4-6。
- 7. 在连接测试中验证 Gateway 可达；不要在屏幕或材料中展示 API Key。
- 8. 清理旧 Demo 数据时确认 durable inbox 没有 pending/retry/processing。
- 9. 打开“监控大屏”和“处置台”两个视图，保持自动刷新开启。

4.2 主演示链路

发送 15 条 Demo Alert

- HTTP 202 + durable inbox
- Dashboard 显示 15 未完成 / 11 等待 / 4 分析中
- 五产品 Agent 调用 Gateway
- Validator 检查证据与权限
- Case、Agent Run、审批建议和审计原子写入
- 队列随完成数自动下降
- 最终 15 completed , Case 工作台显示三类结论

推荐命令：

```
python3 scripts/send_demo_alerts.py
```

只提交、不等待时：

```
python3 scripts/send_demo_alerts.py --wait-seconds 0
```

4.3 必看画面

画面	应展示的信号	讲解重点
监控大屏	未完成、等待、分析中、产品分布、三类结论	证明真实异步处理，而不是脚本预先写 Case
Case 详情	原始告警、NormalizedEvent、证据维度、缺失证据、模型运行元数据	证明结论可追溯、模型后端可核验
处置审批	approve_required、Validator 状态、审批票	证明 AI 只建议，不直接执行
记忆治理	pending/active/quarantined、五道门禁、匹配分解	证明经验可复用但不自动污染长期记忆
日志接入	Mapping Profile、infer、dry-run、五产品端口	证明真实日志先映射验证，再进入 LLM

4.4 建议补充的故障演示

- 10. 临时让 Gateway 不可达，提交一条脱敏样本。
- 11. 展示 Case 仍能产生，但摘要标记“LLM 降级为本地启发式”。
- 12. 展示 model_runtime.fallback_used=true 和审计中的 analysis_failed。
- 13. 强调这是可用性降级，不应把本地结论伪装成远程模型判断。

五、业务痛点与能力映射

银行 SOC 痛点	当前 Demo 对应能力	价值	当前边界
五类安全系统字段不一致	Mapping Profile、自动指纹、NormalizedEvent	降低接入和人工字段对齐成本	厂商专用模板仍需真实脱敏日志校准
告警量大、误报多	三类研判、产品长期记忆、MemoryMatcher	复用已审批误报经验，减少重复分析	尚未用历史生产集量化降噪比例
研判依赖个人经验	产品 Agent、组织知识、结构化解释	把分析顺序和证据要求固化为可审计能力	企业 Playbook/CMDB 尚未接入
响应不及时	durable inbox、4 worker、自动 Case	接入与分析解耦，队列状态可见	当前观测延迟受外部 Gateway 影响，未完成容量压测
关键字段被 SIEM 截断	原始告警留存、stack trace 映射、evidence refs	保留判断攻击是否触达危险 sink 的证据	取决于上游是否把完整原文送达网关
跨产品关联弱	统一 Case、15 分钟实体关联上下文	为分析提供同实体近期多产品证据	还不是完整攻击图或多 Agent 扇出编排
处置缺闭环	Validator + Response Advisor + 审批状态机	把建议放进受控流程	尚未接入 SOAR/工单执行与签名回写
敏感数据出域风险	prompt 前脱敏、主机 allowlist、外部 Gateway 统一入口	缩小模型输入面并保留审计	生产仍需 DLP、mTLS、密钥管理和出域审批

六、安全治理成果

6.1 六类核心风险控制

风险	当前控制
幻觉与误判	结构化输出、证据锚定、维度一致性、缺证据降级、确定性 Validator
敏感信息泄露	字段脱敏、prompt 长度限制、原始证据本地留存、端点与主机校验
越权与过度代理	read_only、Skill blocked tools、approve_required、无 execute API

风险	当前控制
提示注入与记忆投毒	不可信输入检查、Validator、五道晋升门禁、隔离/撤销/过期/冲突治理
合规与审计	RawAlert/Event/Run/Validation/Approval/Memory/Audit 全链路关联
模型与供应链依赖	local/Ollama/Gateway 可切换、失败降级、标准库优先、离线部署物料

6.2 审批不是执行

当前审批状态机用于验证治理流程：

```
pending → approved / rejected / cancelled
execution_status 始终为 not_executed
```

这条边界必须保留到企业集成阶段。未来接入 SOAR 时，应新增独立的签名请求、回写和回滚记录，而不是把现有审批表直接改成可执行工具。

七、当前差距与风险

7.1 不能对外过度表述的能力

不应声称	当前真实状态
已完成生产化	当前是可运行 Demo / PoC 基线，生产组件仍需替换和集成
已实现完整 SIEM Fusion 多 Agent 攻击链	已有 SIEM Agent 和跨产品上下文，尚未形成图谱化攻击链及多 Agent 扇出
已接入 CMDB/IAM/SOAR	尚未接入；资产画像主要从告警实体派生
已有企业向量库	当前使用离线稳定哈希向量，适合确定性 Demo
已达到 30 秒 SLA	本轮 Gateway 观测为 24.0–211.8 秒，需容量和供应商联调
Demo 证明模型准确率	Demo 带真值校正，只证明链路和治理；质量需盲测

7.2 发布前 P0

- 14. 修复当前完整测试中的 2 个断言差异，恢复全绿基线。
- 15. 建立不带 Demo 真值头的脱敏盲测集，区分 attack / suspicious / benign 并由分析师标注。
- 16. 输出模型质量、置信度校准、P95/P99 延迟、Gateway 错误率和降级比例。
- 17. 为文档和 Dashboard 增加构建版本、模型运行元数据和演示数据时间戳。
- 18. 用至少一个真实厂商的脱敏 Syslog/JSON 完成端到端接入验收。

八、下一阶段路线

阶段	重点	验收结果
P0：Demo 收口（1-2 周）	全测试通过、盲测集、演示脚本、结果快照、文档一致性	可重复、可解释、不过度表述的 Demo 基线
P1：企业 PoC（3-6 周）	API Gateway/mTLS、角色 IAM、真实日志、CMDB 查询、PostgreSQL、企业 LLM Gateway	在隔离内网完成真实数据合同和受控分析
P2：质量门禁（4-8 周）	Golden set、对抗集、模型/Prompt/Skill 版本对比、CI 发布门禁	每次变更有可审计评测报告
P3：处置集成（6-10 周）	工单/SOAR 审批、签名回写、执行结果与回滚证据	AI 仍不直接执行，既有流程完成受控处置
持续运营	记忆复核、阈值校准、规则反馈、成本与延迟治理	误报解释时间下降、严重误判受控、审计完整

九、管理决策建议

建议本阶段确认以下决策：

- 19. **确认产品定位不变**：把项目作为“受控分析与治理层”，不转向自动攻击或无审批处置。
- 20. **确认下一阶段验收重心**：从“功能是否能跑”转为“真实数据合同、盲测质量、容量和审计是否达标”。
- 21. **确认企业依赖 Owner**：SOC 提供样本与标注；平台团队提供 API Gateway/K8s/PostgreSQL；安全治理提供 IAM/审批/审计要求；业务 Owner 提供变更窗口和误报确认。
- 22. **确认成功指标**：用人工分析时间、误报重复研判量、证据完整率、严重误判率、Gateway 降级率和审计覆盖衡量，不以自然语言“看起来合理”作为验收。

附录 A：复核证据

证据	位置
项目入口与部署说明	README.md
当前架构与时序	docs/ARCHITECTURE.md、docs/DEMO_ARCHITECTURE.md
Defense Agent 与审批边界	docs/PHASE2_DEFENSE_AGENT.md
多层记忆治理	docs/MEMORY.md
Syslog 与 Collector	docs/SYSLOG_INGESTION.md
Demo 批量脚本	scripts/send_demo_alerts.py

证据	位置
自动化测试	tests/，当前发现 183 个测试方法
Demo 事实快照	data/gateway.db，15 条 10:50:16 批次记录

附录 B：汇报口径

- “已实现”表示当前仓库存在可运行代码和测试/数据证据。
- “部分实现”表示已有内部契约或 Demo 实现，但缺少企业组件或生产验证。
- “规划”表示当前仓库没有对应生产能力，不应在演示中表述为已完成。
- 文中性能数字仅为 2026-07-15 单次 Demo 快照，不构成生产 SLA。